

DMS 优化与踩坑记录

DMS 文档管理系统 —— 细节优化与踩坑记录

> 版本：1.0.0

> 这份文档记录**不是"功能"，但直接决定系统好不好用、好不好维护**的改动。

> 每一条都写清「原来什么样 / 为什么会有问题 / 怎么改的 / 怎么验证」，

> 目的是让后来人不必再踩一遍，也能判断某处代码为什么长这样。

1. 权限模型：把"档位"设计成嵌套的

****原来****：权限位是散着用的，前端要自己判断"只读能不能改名""读写能不能授权"，各处口径不一。

****问题****：多主体授权（用户 + 角色 + 部门）是**取并集**的。如果档位不嵌套（比如"读写"不含"只读"的位），

就必须写一套优先级比较逻辑，而且任何一处漏写就会出现"拒绝了却还能看"这类越权。

****改法****：档位定义成嵌套：`只读(3) ⊂ 读写(55) ⊂ 完全控制(191)`，并集运算天然满足

「完全控制 > 读写 > 只读」；只有「禁止访问(256)」是拒绝位，单独一票否决。

前端 `types/doc.ts` 是档位与权限位的**唯一**定义处，后端 `PermissionFlag` 与之逐位对应。

****验证****：`tools/verify\_permissions.py` 用 40 项检查覆盖四档 + 下载开关 + 优先级。

2. 谁是真超管：按用户 ID 判定，不按角色

****原来****：超管资格来自「超级管理员」角色。

****问题****：角色数据是可改的。一旦有人误删角色-菜单关联、或把该角色错配给别人，

就可能把所有人锁在系统外——而"救场"恰恰是最需要超管的时候。

****改法****：`LoginHelper.isSuperAdmin()` 判定的是**用户 ID 常量**，权限串 `\*:\*:\*` 由

`SysPermissionServiceImpl` 按 ID 注入。「超级管理员」角色行降级为****空壳****（0 条菜单），

不允许分配给其他用户——分了也不产生任何权限，只会让"谁是管理员"变得看不出来。

****顺带修掉的 bug****：原来那句"不允许为普通用户分配超级管理员角色"的守卫，

判断的是****被操作的用户****而不是****操作者****，参数用错。现在一律剔除该角色并给出准确提示。

3. 文档授权：能力闸门 + 范围闸门

****原来****：授权接口写死判超管。

****问题****：只有一个人能配权限，多人维护时无法分担；但一旦简单放开，

拿到「完全控制」的人就能给自己复制权限（自我提权）。

****改法****：两道闸门——① 权限串 `doc:perm:grant`（由超管在「角色管理」勾给某角色）；

② 目标资源上要有「完全控制」位。只查①会越权改别人的目录，只查②会自我复制提权。

****顺带****：把建库时就存在、却从未被任何代码引用的两个"死权限串"

（`doc:perm:grant`、`doc:perm:full`）真正接上，于是「角色管理」里那两行名副其实了。

被委派的人也不再需要放开「用户管理/角色管理/部门管理」——授权弹窗的主体名单走

`/api/perm/subjects`，只返回名字。

4. 审计日志：旁路、留痕、按水位线清理

- ****旁路****：审计写入失败绝不让业务失败（业务成功是主目标）。

实现上是 try/catch 包住写入并只记 warn。

- ****留痕****：清除日志是不可逆且销毁追责证据的操作，****只有内置超管****能做；

且清除后****立刻补记一条 `AUDIT\_CLEAR`****——如果先记再删，这条自己也会被删掉，

就成了"日志被清过但查不到是谁清的"。

- ****导出****：CSV 带 UTF-8 BOM，Excel 打开中文才不乱码；导出上限可配置，避免几百万行把内存吃光。
- ****测试脚本的收尾****：验收脚本一律按"起始最大 `log\_id` 水位线"清理自己产生的记录

(只按临时用户 ID 删是清不掉的——超管令牌产生的记录属于超管)。

5. 上传：tus 断点续传 + 临时文件必须有人清

****问题****：现场网络不稳、文件大（单文件上限 10GB）。普通表单上传中断就得从头再来；

而 tus 的过期机制****不会自己跑****，中断的上传会一直留在磁盘上，实测攒到 300MB 以上。

****改法****：

- 上传走 tus（前端 tus-js-client/uppy，后端 tus-java-server），落盘 ``/var/dms/tus``；
- ``TusCleanupJob`` 每天 04:20：先调 tus 官方 ``cleanup()``，再按目录时间戳兜底删超过 48 小时未变动的残留，

占用超过 5GB 打 ERROR 作为告警触发点。

- 效果：311.3MB → 31.0KB。

6. 预览：三条路径，各管一段

类型	路径	为什么
图片	原图/缩略图 + PhotoSwipe 图集	直接用浏览器能力最清晰
视频	服务端 ffmpeg 转 mp4 + Plyr	浏览器对 mkv/avi 等格式支持差，转码后一定能放；Plyr 而非 Video.js：体积小、样式好接管
音频	Plyr + 原生解码	—
PDF / Office / CAD / 压缩包等 75+ 种	OnlyOffice (iframe)	原生观感 + 可在线编辑
未装 OnlyOffice 时	服务端 LibreOffice 转 PDF + pdf.js	让"要不要装 OnlyOffice"成为可选项，而不是硬依赖

****图片/视频为什么要签名直链****：``/`` 带不上 ``Authorization`` 头，

直接指向 ``/preview`` 会被判未登录（后端返回 200 + ``code:401``，浏览器只当"加载失败"）。

所以签发短期 HMAC 令牌（默认 120 分钟），控制器每次访问**重新校验该用户对该文件的预览权限**。

7. 打包下载：小包同步、大包异步

大目录同步打包会把请求挂很久甚至超时。现在：小于阈值（默认 200 文件 / 500MB）同步流式打包；

超过则转异步任务（`doc_export_task`），前端在「导出任务」页看进度。

异步任务有并发上限、保留 24 小时过期、以及"僵尸任务恢复"定时任务（进程重启后把卡住的任务捡起来）。

8. 系统信息页：观测优先

两条硬规矩：

1. **采集失败不能让页面挂掉**——MinIO/Redis 挂了，其余部分照常显示，对应分组给 `error` 字段说明原因

（运维页面最忌讳"整页白"）；

2. **不做重活**——对象统计设上限（20 万），避免大桶把采集请求拖死。

****安全红线****：MinIO 的 Secret Key **绝不出现在接口返回里**，页面只显示掩码后的 Access Key 与

"Secret Key 已配置"。这条有自动化断言守护：`tools/verify_system_info_page.py` 会拿服务器上真实的

secret 去返回体里搜（并且先断言"确实取到了值"，避免空转式假绿）。

9. 目录可写性：systemd 沙箱踩的坑（配置改造类事故第一名）

****现象****：上传站点图标报 `Read-only file system`。

****原因****：systemd 单元用了 `ProtectSystem=strict`，只有 `ReadWritePaths` 白名单里的目录可写；

`/opt/dms/site-assets` 不在白名单里、属主还不是应用账号。****favicon** 上传因此坏了很久没

人发现**

（谁都没在页面上传过图标）。

****改法****：安装脚本统一创建目录 → ``chown dms:dms`` → 并把站点资源目录写进 ``ReadWritePaths``。

文档里明确写：****新增任何应用要写的目录，两件事都要做（建目录 + 改白名单）****。

10. nginx：只留一个配置文件

****现象****：``nginx -t`` 一直有 ``conflicting server name "_" on 0.0.0.0:80, ignored`` 警告。

****原因****：``sites-enabled/`` 里除了正式配置还躺着 3 个 ``.bak`` 文件——

``include sites-enabled/*`` 会把它们一起加载。****谁生效取决于文件名字典序****，

只是恰好正式配置排在前面而已。这种“看起来没事”的配置最坑人：改个文件名行为就变了。

****改法****：备份移到 ``/root/nginx-backups-<日期>``，``sites-enabled/`` 只留一个符号链接；

发布包里也是单文件。另外把 OnlyOffice 的反代规则排在后端反代****之前****

（``/doc/`` 是协作会话端点，被后端正则抢先匹配就会 404）。

11. 文档服务缓存链接签名：****"除了图片和视频都打不开"的真凶****

****现象****：打开任何 PDF/Word/Excel/CAD 都弹「错误 / 下载失败」；编辑器界面本身能加载、甚至能显示文件名与页数；****图片、视频完全正常****。

****原因****：OnlyOffice 给缓存地址 ``/cache/files/...`` 签名，用的是配置里的

``storage.fs.secretString``；而****校验签名的是 nginx****，用 ``$secure_link_secret``。

后者由容器环境变量 ``SECURE_LINK_SECRET`` 决定，****不给就是每次重启随机生成****。

两者不一致 → 校验必然失败（403）→ 编辑器拿不到文档本体 → 「下载失败」。

容器****重建时漏传这个环境变量****就会立刻出问题。

****为什么容易被误判成对象存储故障****：图片/视频不走 OnlyOffice，所以“只有文档打不开”。

但从应用经 MinIO 读原件的链路（`/api/onlyoffice/file/\*`）一直是 200、MinIO 侧零鉴权失败——

****与 MinIO 无关**。**

****定位方法（很值得记下来）**：**

1. A/B 对照：把容器 nginx 里 `/cache/files` 段的签名校验临时注释掉 →

若同一地址从 403 变 200，就锁定是签名问题（而不是文件缺失/权限/路径）；

2. 反推签名：URL 里的 `md5` 应等于 `BASE64URL(MD5(expires + uri + storage.fs.secretString))`，

与哪个密钥算出来一致，就知道签名用的是哪个值。

****改法**：** 三处对齐同一个密钥（官方要求）——容器环境变量 `SECURE\_LINK\_SECRET`、

`local.json` 的 `storage.fs.secretString`、nginx 的 `\$secure\_link\_secret`。

`install-onlyoffice.sh` 现在会生成一次、持久化到 `/opt/onlyoffice/.secure\_link\_secret`、

重建时复用，并在装完****自检三处是否一致****（不一致直接失败退出）。

****同类第二处**：** nginx 的 OnlyOffice 反代路径清单里漏了 `downloadfile`，

`POST /downloadfile/` 会落到 SPA 规则返回 405，文档同样取不到。

清单来源不要靠猜：容器内 `grep -hE "location" /etc/nginx/includes/ds-\*.conf`，

加上客户端 JS 里 `grep -rhoE "/(downloadfile|readfile|uploadfile|savefile|upload|converter)"`。

****验收方式的改进**：** 原来的检查只断言"弹窗里有 iframe"——于是在"编辑器加载了但文档没取到"时

依然是绿的。现在 `tools/browser\_check\_onlyoffice\_docs.mjs` 断言的是：

编辑器内****没有****「下载失败」+ `/cache/files` 请求****全为 2xx**** + 文档本体****真的解析出来****（页数/表名）。

12. 打包与验收脚本自身的坑（会制造假绿，必须修）

坑	后果	修法
---	----	----

口令读取块被贴进函数体	TDZ 报错或静默回落到`admin123`，表现为"密码错误"	提到模块级；读取失败**大声报错**而不是静默回落
登录函数收了`user/pass`参数却把`admin`写死	"只读用户不能下载"那段其实一直用超管在跑，断言自欺欺人	用传入的账号；并核对`localStorage`里的用户名，确保真的换了账号
只删数据库行、不删对象存储	MinIO 里攒孤儿对象，"对象数 vs 文件数"对不上，看着像丢文件	收尾跑`tools/minio_sweep_orphans.py`（默认只报告，`--delete`才动手；逐个删不用递归——递归删曾误删过真实预览图）
先改 hash 再 reload	守卫用旧的内存登录态把页面踢到登录页，reload 又把`#/login`带回来	刷新之后再切 hash
在已有依赖的机器上收集离线包	只下载"没装的"包 → 离线依赖集不完整，干净服务器上装不起来	给 apt 一个**空的 dpkg status** 解析完整闭包（`fetch-offline-deps.sh`）
脚本没有可执行位就打包	部署方一执行就`Permission denied`	`build-release.sh`里显式`chmod 0755`，不依赖开发机 umask

13. 其它小而值得的改进

- **` .gitignore` 与构建状态**：本机构建产物（`.javac-home/`、`.npm-cache/`）曾被误提交，

已加入忽略并从版本库移除。

- **演示账号**：随包 SQL 带 RuoYi 的`test/test1`（口令是公开的 666666）。

安装脚本会**自动停用**它们，并把`sys\_oss\_config`对齐到本机 MinIO 凭据

（框架默认值`minioadmin/minioadmin123`会让走 OSS 的功能失败）。

- **迁移脚本里的环境相关值**：某条迁移把`documentBaseUrl`写成了上一台服务器的 IP，

换台机器装就会指向错误地址；已改为留空 = 用配置文件的值。

（同时修掉了该文件末尾一条 `INSERT ... VALUES ON CONFLICT` 的非法语句——带 `ON\_ERROR\_STOP` 执行时会让**后续迁移全部不跑**。）

- ****数字类型****：雪花 ID 19 位超出 JS 安全整数范围，后端统一按字符串序列化；前端任何地方都不允许 `Number(id)`。`sum()/count()` 这类值也可能是字符串，格式化时显式 `Number()`，否则 `x === 0` 这类判断会失效。

- ****时区与语言****：JVM 显式 `-Duser.timezone=Asia/Shanghai`
`-Duser.language=zh`，

否则审计时间会写歪（并已在「系统信息」页展示生效值，一眼可核对）。

- ****日志容量****：应用日志按天轮转保留 14 天；journald 限制 512MB / 30 天（默认不限制，长期运行会把 `/var/log/journal` 撑大）。

- ****配置优先级****：OnlyOffice 的几个地址/密钥搬到 `sys\_config`，页面改完即时生效、不用重启；代码里顺序是 `sys\_config` → 配置文件 → 内置默认`。